

Security+ 5.2 · Risk Management Strategies

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.2 — Risk Management Strategies (3:12)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Risk response strategies: MITIGATE (reduce with controls), TRANSFER (shift to another party — insurance, third party), ACCEPT (accept and assume residual risk, documented), AVOID (do not perform the activity).

High-Yield Core Concepts Tested on Exam

- MITIGATE: reduce risk with controls. TRANSFER: shift to insurance or third party. ACCEPT: assume residual risk.
- AVOID: do not perform the activity — the most radical response
- Risk response is chosen based on risk appetite and cost-benefit analysis
- Residual risk remains after any response and must be documented for ACCEPT
- TRANSFER does not eliminate risk; it shifts financial impact to another party

Exam Tips & Classic Scenarios

- 'purchasing cyber insurance' = risk transfer
- 'implementing a firewall' = risk mitigation
- 'deciding not to launch a product' = risk avoidance
- 'accepting the risk and documenting it' = risk acceptance

Typical Exam Scenario: 'Company purchases cyber insurance' = transfer (the risk remains, the insurer pays).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.2 — Risk Management Strategies)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Purchasing cyber insurance to cover the loss from an attack is which risk response?

- A)** Accept the risk
- B)** Avoid the risk
- C)** Transfer the risk
- D)** Mitigate the risk

2. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

3. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'AVOID: does not perform the activity — the most radical response'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: AVOID: does not perform the activity — the most radical response...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'purchasing cyber insurance' = risk transfer. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'purchasing cyber insurance' = risk transfer...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'company buys cyber insurance'=transfer (the risk remains, the insurer pays).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'company buys cyber insurance'=transfer (the risk remains, the insurer pays...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'MITIGATE: reduces. TRANSFER: shifts to insurance. ACCEPT: assumes residual'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: MITIGATE: reduces. TRANSFER: shifts to insurance. ACCEPT: assumes residual...

7. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'AVOID: do not perform the activity — the most radical response'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: AVOID: do not perform the activity — the most radical response

8. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'purchasing cyber insurance = risk transfer.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'purchasing cyber insurance' = risk transfer...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: "company buys cyber insurance'=transfer (the risk remains, the insurer pays)." What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'company buys cyber insurance'=transfer (the risk remains, the insurer pays...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Risk Management Strategies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual....
- D)** Allow shared access among administrators with generic credentials



COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Transfer the risk.

✓ **Why it is correct:** The correct answer is: Transfer the risk. In the Risk Management domain of CompTIA Security+ SY0-701, risk responses include avoid, mitigate, transfer, and accept. Risk transfer occurs when the organization shifts the financial responsibility for a risk to a third party, typically through cyber insurance, outsourcing contracts, or indemnification clauses. By purchasing cyber insurance, the company pays a premium so that the insurer covers losses resulting from attacks, such as recovery costs, regulatory fines, extortion, and civil liability. It is important to note that transfer does not eliminate the risk itself (the attack can still occur), but transfers the financial impact. The organization must still maintain security controls to manage the probability and residual impact.

✗ **Why the others are wrong:**

- *Accept the risk:* Accepting the risk means recognizing the existence of a risk and deciding not to take any action to mitigate or transfer it, usually because the cost of mitigation exceeds the benefit or because the risk is considered acceptable within the organization's risk appetite. Purchasing insurance is not accepting the risk, as it involves an active action of financial transfer. Acceptance is passive and does not involve third parties.
- *Avoid the risk:* Avoiding the risk means eliminating the activity or process that generates the risk. For example, disabling a vulnerable service or prohibiting the use of USB devices. Purchasing insurance does not avoid the risk; the activity continues to exist and the attack can still occur. Avoidance is a behavior change to eliminate exposure, while insurance deals with financial consequences.
- *Mitigate the risk:* Mitigating the risk means implementing controls to reduce the probability or impact of an incident. Examples include firewalls, encryption, awareness training, and backups. Purchasing insurance does not reduce the probability of an attack nor the technical impact; it only financially compensates for losses. Therefore, it is not a mitigation measure, but a transfer.

2) B — Implement the corresponding solution: MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual. These are core risk response strategies: mitigation reduces risk, transfer shifts risk (e.g., insurance), and acceptance retains residual risk.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) B — Implement the corresponding solution: AVOID: does not perform the activity — the most radical response....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 5.2 (Risk Management Strategies): AVOID: does not perform the activity — the most radical response. Risk avoidance involves eliminating the risk by not engaging in the risky activity altogether.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: 'purchasing cyber insurance' = risk transfer....

✓ Why it's correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): 'purchasing cyber insurance' = risk transfer. Risk transfer involves shifting the financial impact of a risk to a third party, such as an insurance company. Cyber insurance is a common method of risk transfer, where the organization pays a premium to transfer the potential financial losses from a cyber incident to the insurer.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: 'company buys cyber insurance' = transfer (the risk remains, the insurer pays....

✓ Why it is correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): 'company buys cyber insurance' = transfer (the risk remains, the insurer pays). Risk transfer shifts the financial impact of a risk to a third party (e.g., insurance) while the risk itself remains. It is one of the risk management strategies (avoid, mitigate, transfer, accept).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: MITIGATE: reduces. TRANSFER: shifts to insurance. ACCEPT: assumes residual....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): MITIGATE: reduces. TRANSFER: shifts to insurance. ACCEPT: assumes residual. Risk mitigation involves implementing controls to reduce risk; risk transfer shifts risk to a third party (e.g., insurance); risk acceptance acknowledges residual risk without further action.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: AVOID: do not perform the activity — the most radical response.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): AVOID: do not perform the activity — the most radical response. Risk avoidance involves eliminating the risk by not engaging in the activity that introduces it.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'purchasing cyber insurance' = risk transfer....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): Risk transfer involves shifting the financial impact of a risk to a third party, typically through insurance or contracts. Purchasing cyber insurance is a classic example of risk transfer.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: 'company buys cyber insurance'=transfer (the risk remains, the insurer pays....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): 'company buys cyber insurance'=transfer (the risk remains, the insurer pays).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Management Strategies): MITIGATE: reduces. TRANSFER: passes to insurance. ACCEPT: assumes residual.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.